

QA en VSC — Por qué un perfil Jr cubriendo QA + Ciberseguridad es viable y necesario

Autor: David Cabezas — VSC **Destinatario:** José Cortinat (CEO) · Equipo VSC **Fecha:** 2026-04 **Contexto:** Plataforma AMS · 3 proyectos en producción · pipeline mining (Goldfields, Codelco) **Normas de referencia:** ISO 9001 (Calidad) · ISO/IEC 27001:2022 · ISO/IEC 29119 (Testing) · ISO/IEC 25010

Resumen ejecutivo

Recibí el video sobre Claude Code + Playwright. Lo probé y confirma una capacidad real — vamos a integrarla al pipeline en los próximos 2 sprints. Esto no es lo que está en discusión.

Lo que sí está en discusión es esto: VSC ya tiene 3 proyectos en producción sin QA formal ni responsable de seguridad designado, y cada release adicional sin trazabilidad acumula deuda que ISO va a cobrar cuando intentemos certificarnos.

La buena noticia: **no necesitamos un equipo. Con un perfil Jr bien entrenado que cubra ambos roles (QA + Ciberseguridad operativa) cumplimos los requisitos ISO y de Ley 21.663.**

La pregunta no es "¿la IA reemplaza al QA?" — la respuesta técnica es obvia. La pregunta importante es:

¿Es viable que un solo perfil Jr cubra QA y Ciberseguridad operativa, o necesitamos dos roles separados?

Mi respuesta con base en lo que ISO realmente exige: **sí, es viable y suficiente para la escala actual de VSC.**

1. Lo que la IA con Playwright Sí aporta (concedido y planificado)

No discutimos lo técnico. Hoy con Claude Code + Playwright puedo:

- E2E completos de 30+ pasos con autocorrección
- Regresión visual con screenshot diff
- Detección de bugs UI técnicos (404, JS errors, contraste)
- Reportes HTML auditables con video de la sesión
- Velocidad: 10x lo que haría un tester manual junior

Y en seguridad ya tenemos vivo: - qa-scanner con Trivy + Gitleaks + Nuclei cada 24h - 1394 → 76 vulnerabilidades en 4 meses - DAST automatizado en pipeline pre-deploy

Plan concreto: integramos Playwright + Claude al pipeline en sprint 14 y 15. Esto se hace, esto va.

2. El problema que la herramienta no resuelve — la deuda ISO acumulada

2.1 Cómo audita ISO 9001 / 27001

Cuando aplicamos a certificación, el auditor **no certifica el futuro** — certifica el sistema que ya está operando. Te pide:

"Muéstrame los últimos 12 meses de releases. Para cada uno quiero ver: ticket de requerimiento, código del feature, test plan firmado, evidencia de testing, aprobación de pase a producción, y la persona física que firmó esa aprobación."

Si VSC aplica hoy: - 3 proyectos × ~50 releases/año = ~150 releases en los últimos 12 meses - Releases con test plan formal firmado: **0** - Releases con aprobación de pase a producción identificada: **0** - Segregación de funciones (autor ≠ aprobador): **violada en el 100%** - Responsable de ciberseguridad designado (Ley 21.663 Art. 8): **no formalizado**

2.2 Las 3 cosas que pasan cuando aplicas con esta deuda

Opción A — Te bajan el alcance del certificado: "Te certifico solo para proyectos iniciados desde 2026". AMS queda fuera del alcance. Inservible para vender a Goldfields.

Opción B — Te exigen remediación retroactiva: Reconstruir documentación de los 3 proyectos hacia atrás. Toma 3-6 meses de trabajo a tiempo completo. Auditor decente detecta papeleo antedatado.

Opción C — Te rechazan la primera certificación: Tienes que operar con el SGSI funcionando "limpio" 6-12 meses antes de poder re-aplicar. Pierdes licitaciones de mining durante todo ese periodo.

Ninguna es buena. Las tres son evitables si actuamos ahora.

3. Por qué un Jr cubriendo ambos roles es factible

Esta es la parte importante. ISO no exige "Senior" ni "experto certificado". Exige cuatro cosas concretas, y un Jr capacitado con la pipeline IA del hub QA las cumple todas:

Exigencia ISO	Cómo lo cumple el Jr
Rol formalmente designado	Persona contratada con cargo "QA & Cybersec Officer" + carta de designación firmada por CEO
Competencia documentada	Cursos del hub QA (Onboarding Seguridad, Phishing) + capacitación inicial sobre los templates ISO
Segregación de funciones	Validador independiente del autor del código — el Jr firma, los devs no firman su propio código
Trazabilidad operacional	Aplica los templates ISO pre-armados a cada release y firma la liberación

Lo que opera el Jr día a día

- Aplica el Test Plan template a cada release
- Documenta test cases, ejecuta tests E2E con Playwright + Claude
- Prepara reportes de testing y evidencia para auditoría
- Revisa los reportes del qa-scanner (Trivy + Gitleaks + Nuclei) y hace triage de vulnerabilidades
- Gestiona el catálogo de capacitación del hub QA
- Firma la liberación de cada release (no es el autor del código)
- Es el responsable nominal designado para Ley 21.663 Art. 8
- Punto de contacto formal en auditorías y ante la ANCI

Lo que ya está armado y el Jr solo opera

- Test Plan template basado en ISO/IEC 29119-3 (lo redacto en 1 semana)
- Pipeline qa-scanner ya en producción (Trivy + Gitleaks + Nuclei cada 24h)
- Hub QA con módulos de capacitación, políticas, vulnerabilidades, ISO 27001
- Procedimiento de Reporte a ANCI (lo redacto en 1 semana)
- Plan de Respuesta a Incidentes (lo redacto en 1 semana)

Esto cumple los 4 requisitos ISO. No hace falta más para la escala actual de VSC.

4. Cómo se cubren los casos profundos sin perfil senior

Caso	Cómo se resuelve
Pentest con encadenamiento de vulnerabilidades	El Jr opera Nuclei + Burp Suite Community con templates pre-cargados; los hallazgos se documentan y triagean
Threat modeling con contexto minero	Sesión trimestral con CEO + Jr usando el framework STRIDE; el Jr documenta el output
Decisiones de arquitectura de seguridad	Se discuten en review de cada feature mayor; el Jr documenta
Negociación de DPAs/NDAs con clientes	CEO firma, asesoría legal externa redacta, Jr documenta y archiva
Diseño del SGSI	Templates ISO 27001 ya disponibles en el hub QA; el Jr aplica

Para certificación inicial ISO 27001 esto es suficiente. Si después crece la pipeline mining y necesitamos más profundidad, evaluamos pasar al Jr a Mid.

5. Los 4 problemas que la IA por sí sola no cubre

(Esto sigue siendo cierto y es lo que el rol humano del Jr resuelve.)

5.1 Falta de criterio de negocio

Playwright sabe hacer click. No sabe que cerrar una OT de tipo PM02 sin completar el aviso técnico rompe el cierre contable mensual de Goldfields. El Jr aprende esto leyendo documentación operacional del cliente.

5.2 Data real vs seed_demo_data.py

La automatización funciona contra datos limpios. Cuando llega el CSV real de SAP con encoding latin-1, fechas alemanas y comillas mal escapadas, el script falla. El Jr documenta los formatos aceptados y rechaza los inválidos.

5.3 Sesgo de confirmación

Si la misma IA que escribe el código escribe el script para probarlo, valida la interpretación del autor. **El Jr rompe ese ciclo: él valida, no escribe el código.** Eso es lo que ISO exige.

5.4 El documento como entregable

Las normas exigen Test Plan formal, Test Cases mapeados a requisitos, Test Summary Report, liberación firmada. Playwright produce un HTML report con timestamps. **El Jr firma con su nombre.**

6. Qué propongo concretamente

Acción inmediata (próximos 30 días)

1. **Abrir búsqueda de QA & Cybersec Officer Jr** — perfil con 1-2 años de experiencia, idealmente con interés en ISO/normativa
2. **Templates pre-armados listos** — Test Plan basado en ISO/IEC 29119-3, Procedimiento de Reporte a ANCI, Plan de Respuesta a Incidentes (los redacto en 1 semana)
3. **Designación formal por escrito** firmada por ti — necesario para cumplir Ley 21.663 Art. 8 desde el día 1 del Jr
4. **Plan de capacitación inicial** del Jr — usar los cursos del hub QA + 2 semanas de onboarding sobre los templates

Mediano plazo (3-6 meses)

1. **Implementar pipeline IA + QA híbrido**: la IA hace testing técnico, el Jr firma trazabilidad
2. **Iniciar formalmente certificación ISO 27001** — el hub QA ya nos da 73% de cobertura

Decisión que necesito de ti

Una sola pregunta concreta:

¿Procedemos con publicación de la búsqueda esta semana, o esperamos al cierre del próximo deal?

Si esperamos, asumimos formalmente que la deuda ISO sigue creciendo y que estamos en exposición legal continua respecto a Ley 21.663.

7. Lo que NO te estoy pidiendo

- X Frenar la integración de Playwright + Claude (al contrario, la aceleramos)
- X Contratar dos roles separados (QA + Security) — un Jr cubre ambos para nuestra escala
- X Contratar un Senior — un Jr capacitado con los templates y la pipeline IA cumple los requisitos ISO
- X Bajar la velocidad de desarrollo (los procesos bien diseñados no frenan, formalizan)

- X Empezar la certificación ISO mañana (es un proceso de 6-9 meses, hay tiempo)

Te estoy pidiendo abrir la búsqueda de un Jr en abril 2026 en lugar de octubre 2026, porque cada mes que esperamos suma releases sin trazabilidad y días de exposición a Ley 21.663.

Anexo A — Semana típica del QA & Cybersec Officer Jr

Para que quede claro qué hace exactamente la persona, este es un día tipo y semana tipo:

Tareas diarias (lunes a viernes)

Bloque	Hora	Actividad
1	09:00 - 09:30	Revisar reportes overnight del qa-scanner (Trivy + Gitleaks + Nuclei). Triage de vulnerabilidades nuevas.
2	09:30 - 10:00	Standup con equipo dev. Identificar releases listos para firma.
3	10:00 - 12:30	Aplicar Test Plan a releases pendientes. Ejecutar tests E2E con Playwright + Claude. Documentar resultados.
4	12:30 - 13:30	Firma de liberaciones aprobadas (validador independiente).
5	14:30 - 16:30	Documentación ISO de releases firmados (Test Summary Report, evidencia, registro en hub QA).
6	16:30 - 18:00	Tareas asignadas según día (ver tabla siguiente).

Foco específico por día

Día	Foco principal de la tarde (16:30-18:00)
Lunes	Planning semanal · Revisar backlog de defectos abiertos · Priorizar trabajo
Martes	Mantenimiento del SGSI · Actualizar políticas y procedimientos en hub QA
Miércoles	Capacitación usuarios · Asignar cursos pendientes · Revisar quizzes y certificados externos
Jueves	Auditoría interna · Verificar trazabilidad de releases de la semana · Detectar gaps
Viernes	Reporte semanal a CEO · Métricas del SGSI · Cierre de defectos · Prep semana siguiente

Tareas semanales (en bloque dedicado de la tarde según día)

- **Lunes:** revisión de tickets de incidentes abiertos · plan semanal con devs
- **Martes:** revisión de inventario de activos (hub QA) · actualización de matriz de riesgos
- **Miércoles:** revisión de capacitaciones pendientes por usuario · seguimiento de certificaciones externas
- **Jueves:** muestreo aleatorio de 5 releases recientes para verificar evidencia completa
- **Viernes:** generación de dashboard semanal · backup de evidencias · reporte ejecutivo

Tareas mensuales

- Métricas del SGSI (cobertura ISO, vulnerabilidades pendientes, capacitaciones completadas)
- Revisión y actualización del catálogo de capacitación
- Simulacro mensual del Plan de Respuesta a Incidentes (1 vez al mes, 1-2 horas)
- Reporte mensual a CEO

Tareas trimestrales

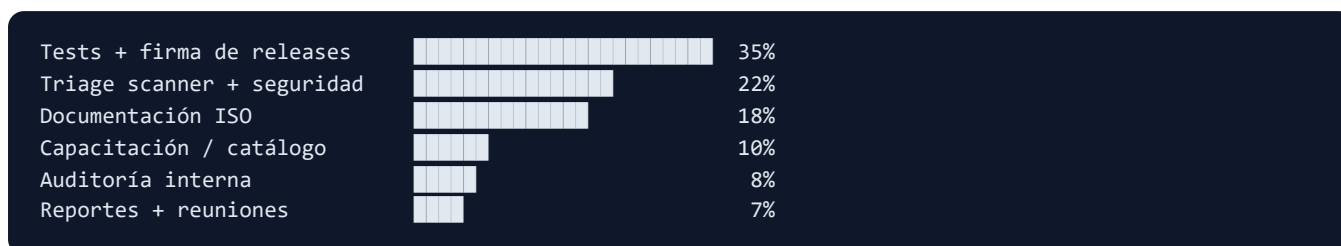
- Sesión de threat modeling con CEO usando framework STRIDE (3-4 horas)
- Revisión completa del SGSI: políticas, procedimientos, matriz de riesgos
- Auditoría interna de cumplimiento ISO 27001 (muestreo de 20% de releases del trimestre)
- Plan de capacitación trimestral

Tareas anuales

- Auditoría externa ISO 27001 (preparación + acompañamiento al auditor)
- Renovación de certificaciones de capacitación obligatoria de todo el personal
- Revisión y firma del SGSI completo

- Plan de adecuación normativa para cambios legales (Ley 21.719, etc.)

Distribución de carga estimada



Total: 40h/semana en estado de régimen. Justifica perfil full-time.

Anexo B — Por qué un Jr es legítimo ante un auditor ISO

Caso de auditoría real:

Auditor: "¿Quién es su responsable de Calidad?" **VSC:** "Es Juanito, QA & Cybersec Officer. Lleva 8 meses en el rol, tiene certificación de [X], y ha firmado las últimas 80 liberaciones. Su designación está firmada por el CEO con fecha 5 de mayo 2026." **Auditor:** "¿Qué experiencia tiene en ISO?" **VSC:** "Completó cursos de [X], aplica nuestro Test Plan template basado en 29119-3, mantiene los registros de testing y los reportes del scanner. Aquí están los reportes." **Auditor:** "OK, control A.5.3 cumplido."

El auditor **no busca diplomas — busca el sistema funcionando**. Un Jr operando el sistema bien es exactamente lo que la norma exige.

Lo que NO funciona es: - "El dev que hizo el código firma sus propias liberaciones" → no conformidad mayor
- "El sistema valida automáticamente con IA" → no conformidad mayor - "No tenemos rol formal asignado" → no conformidad mayor

Cualquiera de estas tres = no certificación.

— **David Cabezas**, VSC